Graphical Authentication System Resistant to shoulder-surfing Attack with Server-Side Hashing

Christo Joby Antony
(U7701030)

Research Proposal - COMP4500
Australian National University
March 2024

Contents

1 Introduction **3**

2 Research Problem **4**
2.1 Key objectives 4

3 Background **4**
3.1 Current State of Authentication Systems 4
3.2 Attacks against Authentication System 4
3.3 Graphical Authentication System 4
3.4 Evaluating Shoulder-surfing Attack 5
3.5 Hashing in Graphical Authentication Systems 6
3.6 Reviewing Related Work 6
3.6.1 CHC - Convex Hull Click Scheme 6
3.6.2 WYSWYE - Where You See Is What You Enter 6
3.6.3 PassMatrix 7
3.6.4 GEAT 7

4 Approach **7**
4.1 Terminologies 7
4.2 The Registration Phase 9
4.3 The Authentication Phase 10
4.4 Storing and Verifying User Secret in Database 11

5 Expected Timeline **12**

6 Evaluation **12**
6.1 Usability and Memorability 12
6.2 Security 13

7 Declaration **14**

1 Introduction

User authentication systems are the first line of defence for digital systems. Therefore, a robust authentication system is paramount for ensuring user privacy and securing digital information. Traditional alphanumeric passwords are widely used due to their ease of implementation and wide user acceptance. However, they are susceptible to security threats like shoulder-surfing, Dictionary attacks, and Key-loggers. Therefore, necessitating alternative authentication methods that offer both security and usability.

Graphical passwords leverage human memory's strength in recalling `images`, which are generally more memorable than alphanumeric strings. However, like their text-based counterparts, graphical passwords are vulnerable to shoulder-surfing attacks. While various research papers have proposed authentication schemes resistant to such attacks, they have usually been at the cost of usability or compromised database security.

This research proposal aims to develop a user-friendly Graphical Authentication System (GAS) that not only provides resistance against shoulder-surfing attacks but also ensures the secure storage of authentication data on the server through robust hashing techniques.

Significance The successful culmination of this research holds the potential to yield an authentication system applicable to critical domains such as finance, national security, and password management. Such an achievement would establish a resilient solution that balances the imperatives of security and usability.

Organisation This research proposal is structured into 5 sections. A brief overview of each section is as follows:

Section	Overview
Introduction	Introduces the research problem and provides context and the significance of this research.
Research Problem,	A formal introduction of the research problem and defines the key objectives and outcomes of the research.
Background	A comprehensive review of relevant literature and previous research on authentication systems. Identifies the areas needing further investigation and establishes the theoretical framework for the study.
Approach	Outlines the design and approach to implement the authentication system.
Expected Timeline	Provides a proposed timeline for the research project, and breaks down major tasks and their expected completion dates.
Evaluation	Establishes a rubric to evaluate the outcome of this research and quantify how well it is able to solve the research problem and address its key objectives.

Figure 1: Overview of the sections

2 Research Problem

The primary focus of this research revolves around the development of an inclusive Graphical Authentication Scheme, tailored to operate effectively within environments characterised by inherent insecurity, while concurrently ensuring secure storage within the database. This overarching aim can be outlined into the key objectives.

2.1 Key objectives

1. The authentication system is user-friendly and accessible to both technical and non-technical users without extensive training.
2. The authentication system should be sufficiently resistant to attack techniques like brute-force, password-guessing, keylogger and shoulder-surfing.
3. The authentication system should be able to store the user secret in the database securely through cryptography techniques like hashing.

3 Background

3.1 Current State of Authentication Systems

User authentication serves as the cornerstone of cybersecurity measures implemented across the Internet. Among the prevalent methods for user verification on modern websites, alphanumeric passwords have emerged as the dominant approach. While theoretically robust, text-based password systems often necessitate a compromise between ease of memorisation and security efficacy [1, 2]. In practice, users frequently opt for passwords that are common and easily memorable, consequently narrowing the pool of potential passwords and rendering systems vulnerable to dictionary-based attacks [13]. Conversely, mandating the selection of complex passwords can lead users to resort to insecure practices such as recording passwords in plaintext documents or on easily accessible mediums like Post-it notes. Furthermore, alphanumeric passwords remain susceptible to a spectrum of attacks, including shoulder-surfing, key-logging, password guessing, and spyware infiltration [8].

3.2 Attacks against Authentication System

A plethora of attack methodologies exploit the nuanced configurations of authentication systems; however, this research primarily concentrates on the theoretical underpinnings of an authentication scheme. Consequently, the delineation of attack strategies herein predominantly revolves around pervasive attack vectors observed across diverse systems. The characterisation of these attacks aligns with the framework outlined in the Survey on Authentication Attacks and Countermeasures authored by Jesudoss A. et al. [24].

3.3 Graphical Authentication System

Graphical Authentication System, is a viable replacement of text based passwords as they can potentially offer a larger password space, theorised to be more memorable than the text

based passwords due to the picture superiority hypothesis demonstrated in psychology studies. [20, 19, 15] Graphical Authentication Systems can be broadly defined as authentication schemes that use pictures and visual cues as user verification instead of alphanumeric characters. Surveys [6, 18] on existing and proposed Graphical Authentication Systems groups them roughly to three categories: "Cognometrics, Locimetrics, and Drawmetrics".

Cognometrics: Cognometrics, also known as recall-based authentication systems, necessitate users to identify a subset of secret images from a larger pool of images, often referred to as distractors [6]. Various iterations of this system introduce innovative schemes or curated image sets aimed at enhancing specific aspects of the authentication process. Notable proposals in this domain include Déjà vu [7], FacePass [4], and Story [5]. Despite their potential, these systems are susceptible to shoulder-surfing attacks, rendering them impractical in compromised environments.

Drawmetrics Drawmetrics, also known as recall-based authentication systems, require users to reproduce a pattern or outline, typically on a grid or similar visual aid. This concept gained prominence with implementations such as the Android Pattern Lock, drawing inspiration from schemes like Draw-A-Secret and PassGo. However, users tend to create simplistic and symmetrical patterns in practice, significantly reducing the password space and leaving them vulnerable to password-guessing attacks, as well as other threats like shoulder-surfing, smudge, and thermal attacks.

Locimetrics Locimetrics, also known as referred to as cue-based authentication systems, leverage visual cues to trigger the recollection of a secret `object` or action, drawing from psychological studies on mnemonic devices [9]. Passpoint, introduced by Wiedenbeck et al. (2005), is a notable example of a Locimetric scheme, wherein users select a sequence of predetermined secret points within a user image. Despite its innovative approach, this implementation remains susceptible to shoulder-surfing attacks and pointer-tracking vulnerabilities.

3.4 Evaluating Shoulder-surfing Attack

Shoulder-surfing attacks are broadly defined as attacks that use social engineering to observe the user during the user verification phase in an authentication system [24]. It is necessary to establish a more precise definition of this attack to better evaluate the existing implementations. Hung-Min Sun et al. [21] have categorised this attack into three types:

Type I: Single Partial Observation of Authentication In this type of attack, the target user is only observed once during the authentication phase. The attacker is observing the authentication procedure in person, and the whole screen may not be visible to the attacker. This attack is typically observed in most public spaces.

Type II: Single Complete Observation of Authentication Here the attacker has a very clear view of the target user's screen during the authentication phase and can track keyboard, touch, and mouse inputs, an extended version of this attack assumes that the attacker can also track the gaze of the target user to identify roughly which part of the

screen the user is looking at. This attack is typically executed using spyware on public computers or using surveillance cameras,

Type III: Multiple Complete Observation of Authentication This attack is also known as Intersection attack[24]. In this scenario, the attacker can repeatedly observe the target user's authentication attempts, thereby the attacker can deduce the secret using the intersection of various attempts. This attack usually occurs when surveillance cameras of offices are hacked or spyware is installed in personal computers.

3.5 Hashing in Graphical Authentication Systems

Most proposals of Graphical Authentication schemes overlook the need for hashing, as they assume that the server-side and client-side systems are secure [21]. This assumption leaves these implementations vulnerable to various server side attacks where sensitive user secret is stored as plain text.
Salting and hashing the user secrets would largely mitigate this vulnerability [11, 10]. However, many shoulder-surfing resistant authentication schemes proposed are impossible to hash, as they require the system to know about the user secret during the creation and throughout the authentication flow. In comparison, in an alphanumeric authentication system, the server only needs to know the user secret at the end of the authentication flow.

3.6 Reviewing Related Work

Numerous research over recent decades have introduced innovative Graphical Authentication Systems with the objective of addressing or enhancing specific facets of the authentication framework. Given the focal point of this study on improving resilience against shoulder-surfing attacks, it is imperative to examine schemes designed to mitigate this particular vulnerability.

3.6.1 CHC - Convex Hull Click Scheme

Proposed by S. Wiedenbeck et al. [22], CHC is a Cognometric scheme that uses Convex Hulls for authentication. In this scheme, the user selects 5 or more pass-icons during the registration phase. In the authentication phase, the user is presented with a series of challenges where some of the pass-icons along with distractors are presented on the screen and the user needs to mentally create a convex-hull bounded by their pass-icon and then click in the bounded region.
While this system is resistant to Type II shoulder-surfing attack. In practice, for a secure implementation with more than 100 pass icons, this scheme can become quite challenging and cumbersome for a user[22, 21] to use reliably without extensive training. The design of this scheme also dictates that hashing the pass-icons in the server is not feasible.

3.6.2 WYSWYE - Where You See Is What You Enter

Proposed by Rohit Ashok Khot et al. [12], WYSWHYE is a Cognometric scheme where grid reduction is used to obscure password entry. In this scheme, the user needs to select a set of password images from a grid of icons. Then the user needs to map the location of

their password image from the original grid to a response grid which has a lower dimension, by applying a "Horizontal Reduction" or "Dual Reduction" scheme.
While this scheme is resistant to Type II shoulder-surfing attack, it is complex for non-technical users and requires training and longer login times[18, 12]. Since the system needs to apply row reduction to verify the user input, the secret images cannot be hashed in the server.

3.6.3 PassMatrix

Proposed by Hung-Min Sun et al. [21] is a Locimetric scheme where a user uses a disposable secret pointer to obscure the selection of the secret location in the image. This secret pointer is displayed to the user through visual or auditory cues at the start of the authentication process.
This scheme is only resistant to Type I shoulder-surfing attack when the secret pointer is shared visually as an attacker, as this implementation assumes that the entire screen is not visible to the attacker. However, it is very intuitive to use, and the secret of a user can be hashed and securely stored on the server.

3.6.4 GEAT

Proposed by Shahzad et al. [17], the Drawmetric scheme presents an innovative approach leveraging user behavioural data to counteract imitation attempts by potential attackers. This authentication system is adaptable for patterns, PINs, or passwords and incorporates Machine Learning techniques to discern between authentic and fraudulent login attempts. The system exhibits user-friendly attributes while demonstrating resilience against Type III Shoulder-surfing Attacks. Nevertheless, its effectiveness is contingent upon substantial user training to accumulate sufficient data for gesture classification. Moreover, the system's functionality requires the presence of a touch screen and accelerometer on the client device, rendering it unsuitable for implementation in web-based applications.

4 Approach

The proposed Graphical Authentication System, NeoAuth, adopts a Cognometric framework designed to mitigate the vulnerabilities posed by shoulder-surfing attacks. It achieves this through the creation of hybrid `images` comprising basic visual elements called `objects`, thereby confounding potential attackers during the authentication process. Central to this scheme is the secure storage of user secrets, facilitated by the assignment of distinct strings to each `object`. These strings are then composed to form a singular, unique secret string, which undergoes hashing prior to storage on the server.

4.1 Terminologies

In the framework of this authentication system, the subsequent terminologies are defined to facilitate a comprehensive understanding of the system's deployment.

Object: is a fundamental unit of this authentication scheme. It is essentially a graphic of common everyday `objects`, that are easily distinguishable and identifiable. There is a defined set of `objects` on the server, with at least more than 48 `objects`. Each `object` is associated with a unique string of text, this is used to hash the user secret later. Therefore, an `object` can be defined as follows:

Let O denote the set of defined n `objects` o_i in the authentication scheme.

$$O = \{o_1, o_2, o_3, ..., o_n\}$$

Each `object` o_i is associated with a unique string of text, denoted by T_i.

$$\{(o_1, T_1), (o_2, T_2), (o_3, T_3), ..., (o_n, T_n)\}$$

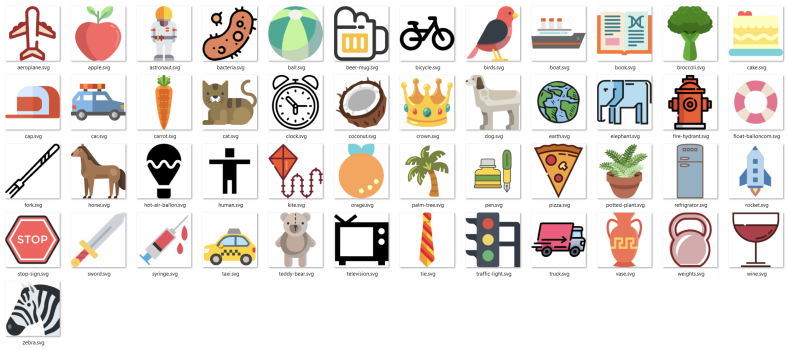


Figure 2: Sample of pre-defined `objects`, sourced from SVGRepo

NeoPass: is a sequence of 6 or more secret `objects` that make up the shared secret between the user and the server. This secret is then stored in the database as a hashed string of text and used to verify login attempts. Therefore, NeoPass can be defined as:

Let S denote the set of sequences of n secret `objects` s_i:

$$S = \{s_1, s_2, s_3, ..., s_n, \ n \geq 6\}$$

Images: is a generated graphic composed of at least 3 or more `objects` manipulated by rotation, scale or skew operations. This `image` is also associated with their corresponding `objects`. Therefore, `images` can be defined as:

Let I denote the set of generated `images` composed of at n or more `objects` o_i:

$$I = \{o_1, o_2, o_3, ..., o_n\}$$

Image Set: is a collection of `images`, that are guaranteed to contain all the defined `objects` exactly once in one of the `image`. Therefore, we can define an `image-set` as follows

Let IS denote the set of m `images` I_i

$$IS = \{I_1, I_2, I_3, ..., I_m\}$$

The set IS is a collection of `images` containing all the defined `objects` exactly once:

$$I_1 \cup I_2 \cup I_3 ... \cup I_m = O$$

$$I_1 \cap I_2 \cap I_3 ... \cap I_m = \phi$$



Figure 3: Sample of an `image` and an `image-set` sourced from SVGRepo

Challenge Set: is a collection of at least 6 or more `image-sets` that can be used to collectively convey the secret `objects` on a user's NeoPass. Therefore, a `challenge-set` can be defined as

Let CS denote the set of `challenge-sets`, which are collections of k `image-sets` IS_i:

$$CS = \{IS_1, IS_2, IS_3, ..., IS_k,\ k \geq 6\}$$

Response Images: is the `image` selected from each `image-set` of a `challenge-set`. This selection is used by the server to determine whether the authentication attempt is valid or not. Therefore, Response images can be defined as:

Let RI denote the Product set of selected `image` I_j and the corresponding `image-set` IS_k:

$$RI = \{(I_1, IS_1), (I_2, IS_2), (I_3, IS_3), ..., (I_m, IS_m),\ m \geq 6\}$$

4.2 The Registration Phase

The registration phase within this scheme can be outlined as follows:

1. **User Identity Verification:** A distinct identifier such as an email address or username undergoes validation against the database to ascertain the novelty of the user.

2. **NeoPass Selection:** Users are presented with a grid comprising all available `objects` stored in the server, tasked with selecting a sequence of `objects` consisting of no fewer than 6.

3. **Selection Repetition:** To preclude inadvertent selection errors, users are mandated to replicate the NeoPass selection in identical order.

4. **Account Creation Confirmation:** Subsequently, users review the details of account creation, and upon confirmation, the credentials are stored within the database. The specifics of how the credentials are stored is discussed in section 4.4

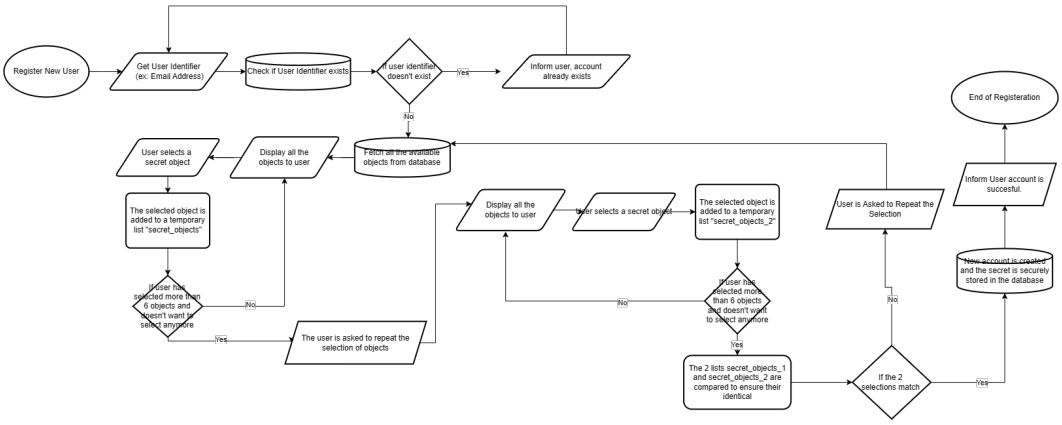


Figure 4: Registration Flow Chart

4.3 The Authentication Phase

The authentication phase within this framework can be outlined as follows:

1. **User Identity Validation:** Initially, the user identifier is input, and a verification process is initiated with the server to ascertain the existence of the corresponding account.

2. **Selection of the Initial Secret `Object`:** Subsequently, the user is presented with an `image-set`, prompting the selection of an `image` containing their initial secret `object` from the NeoPass.

3. **Sequential Entry of Subsequent Secret `Objects`:** This process iterates, with the user repeatedly engaging with new `image-set` to select successive secret `objects` until all designated `objects` have been chosen.

4. **Submission for Authentication:** The client then forwards the chosen `images` from each `challenge-set` to the server for authentication verification.

5. **Authentication Verification:** The then server computes all conceivable permutations of `object` sequences from the selected `images` and generates corresponding

hashes. These computed hashes are subsequently compared with the stored secrets in the database.

6. **Outcome of Authentication Attempt:** Should a match be identified between the hashes, the authentication attempt is deemed successful; otherwise, it is rejected.

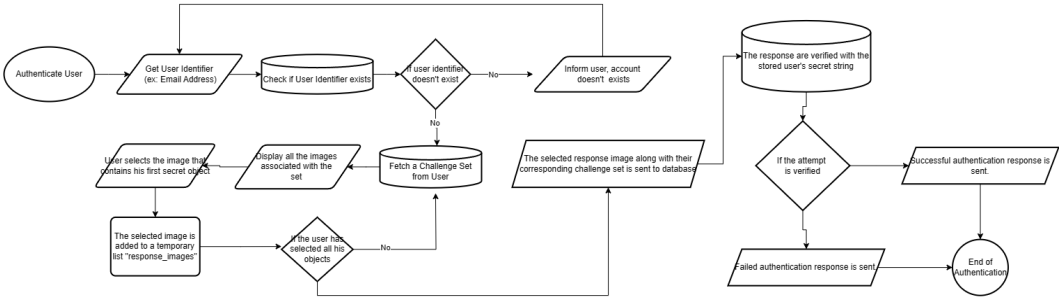


Figure 5: Authentication Flow Chart

4.4 Storing and Verifying User Secret in Database

This implementation proposes the utilisation of hash function like PBKDF2, BCrypt or Argon2 to securely store the secret of users in the Database. These modern hashing algorithms are specifically designed to better slow down the attacker by making the hash algorithm computationally intensive [14, 16].

Hash Generation Process: The hash of the user's NeoPass is computed using the following algorithm:

1. The distinctive identifying string of each secret `object` is retrieved from the database.
2. An intermediate secret string is constructed by concatenating the retrieved secret strings.
3. The intermediate secret string is augmented with a user-specific salt, which may be as straightforward as the user identifier.
4. Subsequently, the salted secret string undergoes storage using a cryptographic hash function.

Verification of the hash: Upon receiving the selected `response-images` from each `image-set`, the verification process is conducted using the following algorithm:

1. The associated string identifiers of the `objects` encompassed in the `response-images` are extracted from the database.
2. Subsequently, a product set encompassing all distinct permutations derived from the `objects` within the `response-images` is formulated.
3. From this product set, a collection of potential intermediate secret strings is generated.
4. These intermediate secret strings undergo salting, following which their hashes are compared with the user's secret string to ascertain any matches.

5 Expected Timeline

To conduct a thorough research of this topic and comprehensively evaluate the outcome of this research, the following schedule will be followed.

Task To Complete	Expected Result	Estimated Duration
To implement the back-end application,	A Web API, Database service and Web Server is implemented.	3 weeks
Implement the front-end application,	A Single-Page Web Application that works with the back-end.	2 weeks
Preliminary UI Testing for Bugs and Glitches,	A robust web application prototype that is secure and reliable.	1 week
Usability and Memorability Evaluation and Feedback	The system is refined iteratively to create a more user-friendly scheme.	2 weeks
Security Evaluation and Feedback	The system's resilience against various attacks methodologies are quantified.	1 week

Figure 6: Tabulation of the expected timeline

6 Evaluation

To quantify the success of this research, the implemented authentication system will be evaluated on the following criteria. The criteria will mainly focus on two aspects of the authentication system, ease of use and security. Creating an authentication system that is secure with minimal effort from the user would be ideal. However, implementing such an authentication system is challenging, if not impossible. Therefore, this evaluation criteria ensure that the proposed authentication system is well-balanced in both areas.

6.1 Usability and Memorability

Significance Braz et al., on their survey [3] of security and usability of authentication system finds that, complex systems that are too demanding from the user negatively impact the security of the system as users will begin to follow insecure practises. This finding has also been reflected on research conducted by M. Yıldırım et al. [23] to improve password systems that conclude "Security issues in text-based password authentication are rarely caused by technical issues, but rather by the limitations of human memory". Therefore, it is important to ensure the authentication scheme is intuitive to for all groups of people to

adopt and use.

Methodology of Evaluation The usability of this scheme can be quantified by testing the system with focus groups and recording the following metrics:

- Ease of registering for the scheme.
- Time required for authentication.
- Learning curve associated with authentication.
- Success rate of authentication.
- Implementation across various devices and screen sizes.

In addition to this, feedback needs to be recorded on perceived security, ease of use, and usability issues, concerns, or feature requests that could inform iterative improvements to the system.

6.2 Security

Evaluating the security of the authentication in this scheme will focus on the following aspects:

Brute Force attack, for an authentication system to be resilient against brute force attacks, it needs to have a large enough password space that makes trying every possible combination of passwords infeasible. Therefore, the password space can be used to quantify the resistance against this attack.

Shoulder-surfing Attack, can be emulated using a video camera to record the authentication process can be used to gauge the effectiveness of the authentication system against shoulder-surfing attack.

Database Leaks, A database leak can be emulated by trying to crack a secret string that could be potentially stolen from the database. The time required to crack it can be used to evaluate the server-side security. This time period can be estimated using either mathematical tools or password cracking tools like HashCat.

7 Declaration

I hereby declare that this research proposal is the result of my own independent effort, unless otherwise specified. Any material obtained from external sources has been duly acknowledged and cited, following academic standards and conventions. I acknowledge the use of AI-Tools like of ChatGPT and Gemini solely for the purpose of grammar verification and language refinement.

References

[1] Anne Adams and Martina Angela Sasse. Users are not the enemy. *Commun. ACM*, 42(12):40–46, dec 1999.

[2] Denis Besnard and Budi Arief. Computer security impaired by legitimate users. *Computers Security*, 23(3):253–264, 2004.

[3] Christina Braz and Jean-Marc Robert. Security and usability: the case of the user authentication methods. pages 199–203, 01 2006.

[4] Sacha Brostoff and M Angela Sasse. Are passfaces more usable than passwords? a field trial investigation. In *People and computers XIV—usability or else! Proceedings of HCI 2000*, pages 405–424. Springer, 2000.

[5] Darren Davis, Fabian Monrose, Michael K Reiter, et al. On user choice in graphical password schemes. In *USENIX security symposium*, volume 13, pages 11–11, 2004.

[6] Antonella De Angeli, Lynne Coventry, Graham Johnson, and Karen Renaud. Is a picture really worth a thousand words? exploring the feasibility of graphical authentication systems. *International journal of human-computer studies*, 63(1-2):128–152, 2005.

[7] Rachna Dhamija and Adrian Perrig. Deja {Vu–A} user study: Using images for authentication. In *9th USENIX Security Symposium (USENIX Security 00)*, 2000.

[8] Niels Ferguson, Bruce Schneier, and Tadayoshi Kohno. *Cryptography engineering: design principles and practical applications*. John Wiley & Sons, 2011.

[9] Kenneth L Higbee. Your memory: How it works and how to improve it. 1977.

[10] Gongzhu Hu. *On Password Strength: A Survey and Analysis*, pages 165–186. 06 2018.

[11] Parves Kamal. Security of password hashing in cloud. *Journal of Information Security*, 10:45–68, 01 2019.

[12] Rohit Ashok Khot, Ponnurangam Kumaraguru, and Kannan Srinathan. Wyswye: shoulder surfing defense for recognition based graphical passwords. In *Proceedings of the 24th Australian Computer-Human Interaction Conference*, pages 285–294, 2012.

[13] Himanshu Kumar, Sudhanshu Kumar, Remya Joseph, Dhananjay Kumar, Sunil Kumar Shrinarayan Singh, Ajay Kumar, and Praveen Kumar. Rainbow table to crack password using md5 hashing algorithm. In *2013 IEEE Conference on Information & Communication Technologies*, pages 433–439. IEEE, 2013.

[14] Kathleen Moriarty, Burt Kaliski, and Andreas Rusch. Pkcs# 5: Password-based cryptography specification version 2.1. Technical report, 2017.

[15] Raymond S Nickerson. Short-term memory for complex meaningful visual configurations: A demonstration of capacity. *Canadian Journal of Psychology/Revue canadienne de psychologie*, 19(2):155, 1965.

[16] Rohan Patra and Sandip Patra. Cryptography: A quantitative analysis of the effectiveness of various password storage techniques. *Journal of Student Research*, 10(3), Oct. 2021.

[17] Muhammad Shahzad, Alex X Liu, and Arjmand Samuel. Secure unlocking of mobile touch screen devices by simple gestures: You can see it but you can not do it. In *Proceedings of the 19th annual international conference on Mobile computing & networking*, pages 39–50, 2013.

[18] Tahmina Shammee, Taslima Akter, Muthmainna Mou, Farida Chowdhury, and Md. Sadek Ferdous. A systematic literature review of graphical password schemes. *Journal of Computing Science and Engineering*, 14:163–185, 12 2020.

[19] Lionel Standing. Learning 10000 pictures. *Quarterly Journal of Experimental Psychology*, 25(2):207–222, 1973.

[20] Lionel Standing, Jerry Conezio, and Ralph Norman Haber. Perception and memory for pictures: Single-trial learning of 2500 visual stimuli. *Psychonomic science*, 19(2):73–74, 1970.

[21] Hung-Min Sun, Shiuan-Tung Chen, Jyh-Haw Yeh, and Chia-Yun Cheng. A shoulder surfing resistant graphical authentication system. *IEEE Transactions on Dependable and Secure Computing*, 15(2):180–193, 2016.

[22] Susan Wiedenbeck, Jim Waters, Jean-Camille Birget, Alex Brodskiy, and Nasir Memon. Passpoints: Design and longitudinal evaluation of a graphical password system. *International journal of human-computer studies*, 63(1-2):102–127, 2005.

[23] M. Yıldırım and I. Mackie. Encouraging users to improve password security and memorability. *International Journal of Information Security*, 18, 12 2019.

[24] Nur Haryani Zakaria, David Griffiths, Sacha Brostoff, and Jeff Yan. Shoulder surfing defence for recall-based graphical passwords. In *Proceedings of the Seventh Symposium on Usable Privacy and Security*, SOUPS '11, New York, NY, USA, 2011. Association for Computing Machinery.